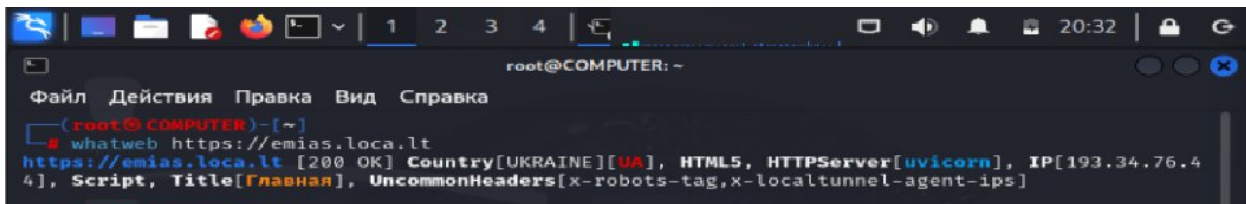


Тестирование на проникновение

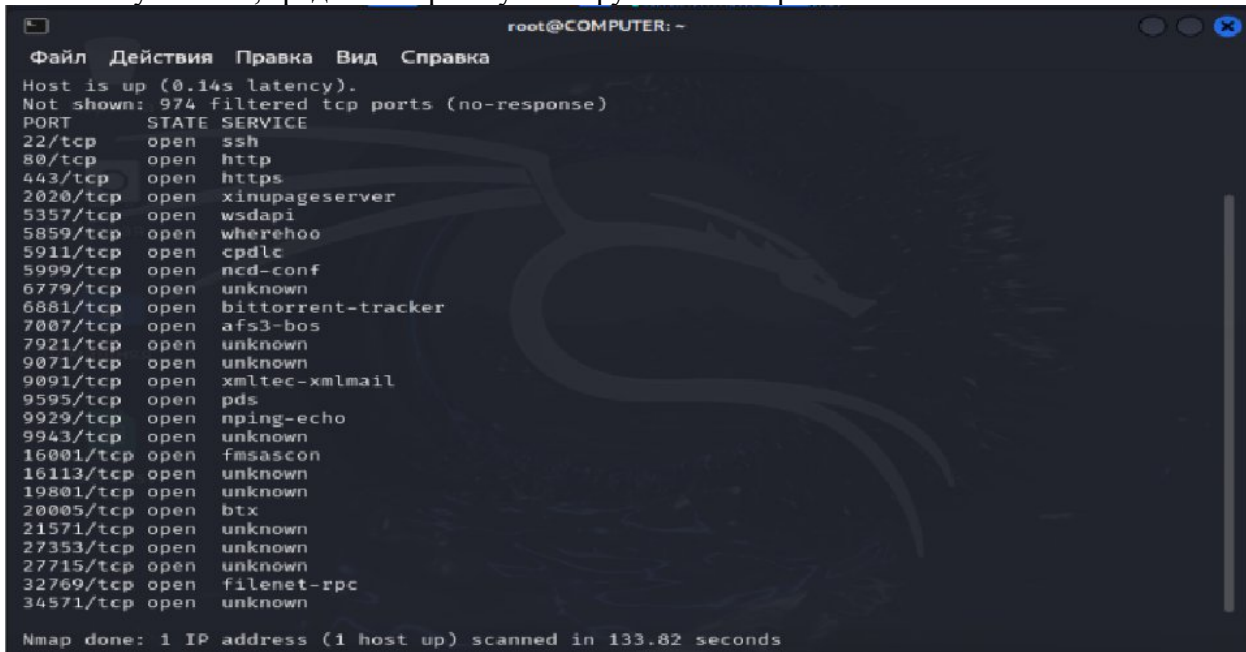
Пентест начался с результатов сканирования самого веб-сайта <https://emias.local.lt> с помощью инструмента whatweb.



```
root@COMPUTER: ~  
# whatweb https://emias.local.lt  
https://emias.local.lt [200 OK] Country[UKRAINE][UA], HTML5, HTTPServer[uvicorn], IP[193.34.76.44], Script, Title[Главная], UncommonHeaders[x-robots-tag,x-localtunnel-agent-ips]
```

Мы получили ответ от хоста что сайт доступен [200 OK], что использовалась современная версия HTML, а также что сервер работает на Uvicorn, который является ASGI-сервером для Python. Получаем IP-адрес: 193.34.76.44.

После получения IP, продолжаем работу с инструментом nmap.



```
root@COMPUTER: ~  
Host is up (0.14s latency).  
Not shown: 974 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
443/tcp   open  https  
2020/tcp  open  xinupageserver  
5357/tcp  open  wsdlapi  
5859/tcp  open  wherehoo  
5911/tcp  open  cpdlc  
5999/tcp  open  ncd-conf  
6779/tcp  open  unknown  
6881/tcp  open  bittorrent-tracker  
7007/tcp  open  afs3-bos  
7921/tcp  open  unknown  
9071/tcp  open  unknown  
9091/tcp  open  xmlltec-xmllmail  
9595/tcp  open  pds  
9929/tcp  open  nping-echo  
9943/tcp  open  unknown  
16001/tcp open  fmsascon  
16113/tcp open  unknown  
19801/tcp open  unknown  
20005/tcp open  btx  
21571/tcp open  unknown  
27353/tcp open  unknown  
27715/tcp open  unknown  
32769/tcp open  filenet-rpc  
34571/tcp open  unknown  
  
Nmap done: 1 IP address (1 host up) scanned in 133.82 seconds
```

Видим все открытые порты на нашем хосте и связанные с ним сервисы.

Потенциальные угрозы:

- Наличие неизвестных сервисов (6779/tcp, 16111/tcp)
- Открытый порт 22/TCP (SSH), может быть подвержен брутфорсу и эксплуатации уязвимостей, так как он используется для удаленного доступа к серверу.

Рекомендации по защите: использовать ключи SSH вместо паролей для повышения безопасности.

- Открытый порт 80/TCP (HTTP), может быть атакован с помощью XSS, SQL-инъекций и других уязвимостей, так как он применяется для доступа к самой веб-странице.

Рекомендации по защите: использовать HTTPS для шифрования данных.

Также можно проанализировать службы, работающие на порту:

`$ sudo netstat -tulpn | grep <номер порта>` - для более быстрого поиска.

После чего посмотреть краткое описание выбранного сервиса:

`$ whatis <имя службы>`

После чего проверяем должен ли этот порт быть открытым, если нет, то закрываем. Таким образом сокращение числа открытых портов упрощает дальнейший контроль и снижает вероятность эксплуатации уязвимостей.

Далее с помощью инструмента sqlmap была совершена проверка на возможное наличие SQL-инъекций, в ходе анализа получились такие результаты:

```
[21:15:07] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[21:16:05] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[21:16:43] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[21:17:20] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[21:17:56] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[21:17:56] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[21:18:03] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[21:18:05] [INFO] testing 'Generic inline queries'
[21:18:07] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[21:18:07] [CRITICAL] considerable lagging has been detected in connection response(s). Please use as high value for option '--time-sec' as possible (e.g. 10 or more)
[21:18:26] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[21:18:28] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[21:18:31] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[21:18:34] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[21:18:43] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[21:18:46] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] y
[21:19:15] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[21:19:22] [WARNING] GET parameter 'id' does not seem to be injectable
[21:19:22] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'
```

Совершены проверки на Error-based, time-based blind, union-based. По дальнейшему разбору логов было выяснено, что большинство запросов были завершены timeout => возможна блокировка.

Проверяемый параметр id не уязвим к стандартным SQL-инъекциям, следовательно веб-сервис защищено от преднамеренно вызванных ошибок СУБД, попыток выполнения нескольких запросов в одном, атаки с задержкой ответов, а также попытки внедрения вредоносного UNION SELECT.

Сервер активно сопротивляется, используя timeout и задержки. Однако отсутствие URL параметров не исключает возможности появления SQL-инъекций, хоть параметр id устойчив к базовым атакам.

Рекомендации по защите: сократить число запросов, проверить логи в PostgreSQL.

Анализ сетевого трафика с помощью инструмента Wireshark.

Анализ HTTP-трафика

Тип трафика: POST-запросы с ответами 200 OK, сервер работает стабильно.

Возможны уязвимости POST-запросов, но с помощью инструмента sqlmap уязвимости типа sql-инъекций, однако можно ограничить POST-запросы по IP для более надежной защиты и работы сервиса.

Пример:

```
location /api {
    limit_except GET { deny all; }
}
```

Делается через фреймворк nginx, там же можно настроить мониторинг и логирование тела POST-запросов, но это лучше делать через скрипты в bash.

```
tshark -Y "http.request.method==POST && ip.dst==193.34.76.44" -T fields -e http.host -e http.request.uri -e http.file_data
```

Анализ IPv4-трафика.

Всего пакетов: 16

Протокол: TCP

Порт: 443 (HTTPS)

Средняя частота: 0.0001 пакетов/мс

Пиковая нагрузка: 0.0300 пакетов/мс

Тип трафика: зашифрованный (HTTPS) – что снижает риск перехвата данных, нет резких всплесков, нет признаков DDoS или сканирования, также сервис не является критически нагруженным.

Для улучшения системы безопасности можно разграничить доступ расширив HTTPS только для доверенных IP:

Это тоже позволяет сделать фреймворк nginx.

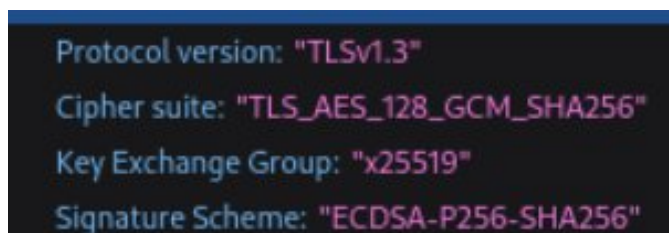
```
server {  
    listen 443 ssl;  
    allow 192.168.1.0/24;  
    deny all;  
}
```

Для углубленного анализа можно заметить:

```
nmap -sV --script ssl-enum-ciphers 193.34.76.44 -p 443
```

Анализ сетевого трафика

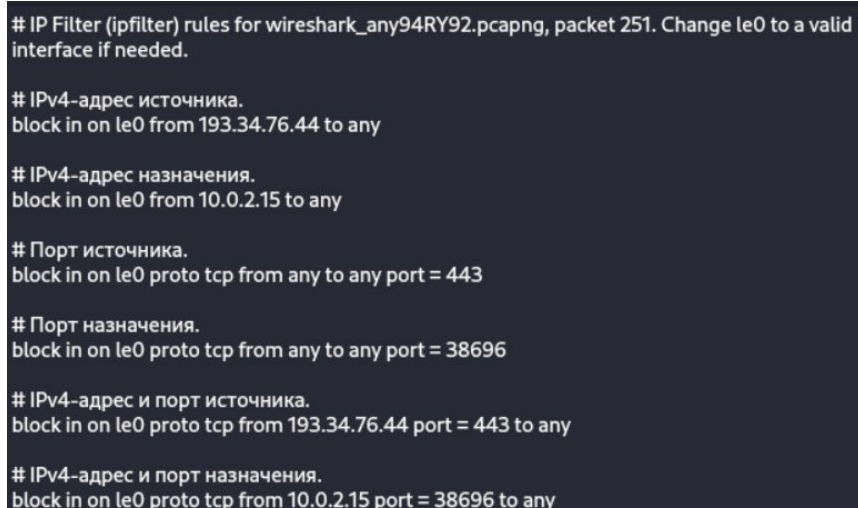
Использование шифрования Cipher suite: TLS_AES_128_GCM_SHA256, обмен ключами: x25519.



```
Protocol version: "TLSv1.3"  
Cipher suite: "TLS_AES_128_GCM_SHA256"  
Key Exchange Group: "x25519"  
Signature Scheme: "ECDSA-P256-SHA256"
```

Проанализировав набор правил для IP Filter в Wireshark, предназначенного для блокировки определенного сетевого трафика, который был зафиксирован в файле захвата пакетов было выяснено, что:

- Обнаружена блокировка исходящего трафика HTTPS (порта 443), что ограничивает доступ к внешним сервисам, а также предотвращает попытки C2-трафика.



```
# IP Filter (ipfilter) rules for wireshark_any94RY92.pcapng, packet 251. Change le0 to a valid interface if needed.  
  
# IPv4-адрес источника.  
block in on le0 from 193.34.76.44 to any  
  
# IPv4-адрес назначения.  
block in on le0 from 10.0.2.15 to any  
  
# Порт источника.  
block in on le0 proto tcp from any to any port = 443  
  
# Порт назначения.  
block in on le0 proto tcp from any to any port = 38696  
  
# IPv4-адрес и порт источника.  
block in on le0 proto tcp from 193.34.76.44 port = 443 to any  
  
# IPv4-адрес и порт назначения.  
block in on le0 proto tcp from 10.0.2.15 port = 38696 to any
```

Анализ графика сетевого трафика TCP/TLS

Время	10.0.2.15	193.34.76.44	Комментарий
47.122996846	38696	38696 → 443 [SYN] Seq=0 Win=6	TCP: 38696 → 443 [SYN] Seq=0
47.257668585	38696	443 → 38696 [SYN, ACK] Seq=0 Ack=1	TCP: 443 → 38696 [SYN, ACK] Seq=0
47.257731537	38696	38696 → 443 [ACK] Seq=1 Ack=1	TCP: 38696 → 443 [ACK] Seq=1
47.258492504	38696	Client Hello (SNL=emias.local.it)	TLSv1.3: Client Hello (SNL=emias.local.it)
47.259117538	38696	443 → 38696 [ACK] Seq=1 Ack=833	TCP: 443 → 38696 [ACK] Seq=1
47.409182318	38696	Server Hello, Change Cipher Spec, ...	TLSv1.3: Server Hello, Change Cipher Spec, ...
47.409246187	38696	38696 → 443 [ACK] Seq=833 Ack=1361	TCP: 38696 → 443 [ACK] Seq=833
48.428383940	38696	Application Data, Application Data, ...	TLSv1.3: Application Data, Application Data, ...
48.428442354	38696	38696 → 443 [ACK] Seq=833 Ack=2400	TCP: 38696 → 443 [ACK] Seq=833

Источник: 10.0.2.15:38696 (динамический порт), назначение: 193.34.76.44:443 (сервер, HTTPS).

Соединение основано на TLS-рукопожатии (HTTPS) с установленными сессиями TCP. Оно стабильно, начало зашифрованного обмена данных проходит хорошо, есть подтверждения полученных данных в многократных пакетах [ACK].

Этаже подтверждается и через анализ потока TCP пакетов.

Время	10.0.2.15	193.34.76.44	Комментарий
47.122996846	38696	SYN	Seq = 0
47.257668585	38696	SYN, ACK	Seq = 0 Ack = 1
47.257731537	38696	ACK	Seq = 1 Ack = 1
47.258492504	38696	PSH, ACK - Len: 832	Seq = 1 Ack = 1
47.259117538	38696	ACK	Seq = 1 Ack = 833
47.409182318	38696	PSH, ACK - Len: 1360	Seq = 1 Ack = 833
47.409246187	38696	ACK	Seq = 833 Ack = 1361
48.428383940	38696	PSH, ACK - Len: 1039	Seq = 1361 Ack = 833
48.428442354	38696	ACK	Seq = 833 Ack = 2400

Packet 260: Seq = 833 Ack = 2400